CRYPTOGRAPHY AND NETWORK SECURITY (Professional Elective — III)

III B.TECH II- SEM

Lecture 1

COURSE OVERVIEW

Course Objectives:

Explain the importance and application of each of confidentiality, integrity, authentication and availability

Understand various cryptographic algorithms.

Understand the basic categories of threats to computers and networks

Describe public-key cryptosystem.

Describe the enhancements made to IPv4 by IPSec

Understand Intrusions and intrusion detection

COURSE OUTCOMES

- **Course Outcomes:**

Student will be able to understand basic cryptographic algorithms, message and web authentication and security issues.

Ability to identify information system requirements for both of them such as client and server.

Ability to understand the current legal issues towards information security.

SYLLABUS

UNIT – I

- **Security Concepts:** Introduction, The need for security, Security approaches, Principles of security, Types of Security attacks, Security services, Security Mechanisms, A model for Network Security Cryptography Concepts and Techniques: Introduction, plain text and cipher text, substitution techniques, transposition techniques, encryption and decryption, symmetric and asymmetric key cryptography, steganography, key range and key size, possible types of attacks.

UNIT - II

- **Symmetric key Ciphers:** Block Cipher principles, DES, AES, Blowfish, RC5, IDEA, Block cipher operation, Stream ciphers, RC4.
- **Asymmetric key Ciphers:** Principles of public key cryptosystems, RSA algorithm, Elgamal Cryptography, Diffie-Hellman Key Exchange, Knapsack Algorithm.

UNIT – III

- **Cryptographic Hash Functions:** Message Authentication, Secure Hash Algorithm (SHA-512), **Message authentication codes:** Authentication requirements, HMAC, CMAC, Digital signatures, Elgamal Digital Signature Scheme.
- Key Management **and Distribution:** Symmetric Key Distribution Using Symmetric & Asymmetric Encryption, Distribution of Public Keys, Kerberos, X.509 Authentication Service, Public — Key Infrastructure

UNIT - IV

- **Transport-level Security:** Web security considerations, Secure Socket Layer and Transport Layer Security, HTTPS, Secure Shell (SSH)
- **Wireless Network Security:** Wireless Security, Mobile Device Security, IEEE 802.11 Wireless LAN, IEEE 802.11i Wireless LAN Security

UNIT - V

- **E-Mail Security:** Pretty Good Privacy, S/MIME IP Security: IP Security overview, IP Security architecture, Authentication Header, Encapsulating security payload, Combining security associations, Internet Key Exchange
- Case **Studies on Cryptography** and **security:** Secure Multiparty Calculation, Virtual Elections, Single sign On, Secure Inter-branch Payment Transactions, Cross site Scripting Vulnerability

TEXT BOOKS

1. Cryptography and Network Security - Principles and Practice: William Stallings, Pearson Education, 6th Edition
2. Cryptography and Network Security: Atul Kahate, Mc Graw Hill, 3rd Edition

REFERENCES

1. Cryptography and Network Security: C K Shyamala, N Harini, Dr T R Padmanabhan, \/ViIey India, 1st Edition.
2. Cryptography and Network Security: Forouzan Mukhopadhyay, Mc Graw Hill, 3rd Edition
3. Information Security, Principles, and Practice: Mark Stamp, Wiley India.
4. Principles of Computer Security: WM. Arthur Conklin, Greg White, TMH
5. Introduction to Network Security: Neal Krawetz, CENGAGE Learning
6. Network Security and Cryptography: Bernard Menezes, CENGAGE Learning

TEXT BOOKS

1. **Alfred J. Menezes**, Paul C. van OorschotPaul C. van Oorschot and Scott A. Vanstone, Handbook of Applied Cryptography, 2011.

Roadmap

- Cryptographic algorithms
  - symmetric ciphers
  - asymmetric encryption
  - hash functions
- Mutual Trust
- Network Security
- Computer Security

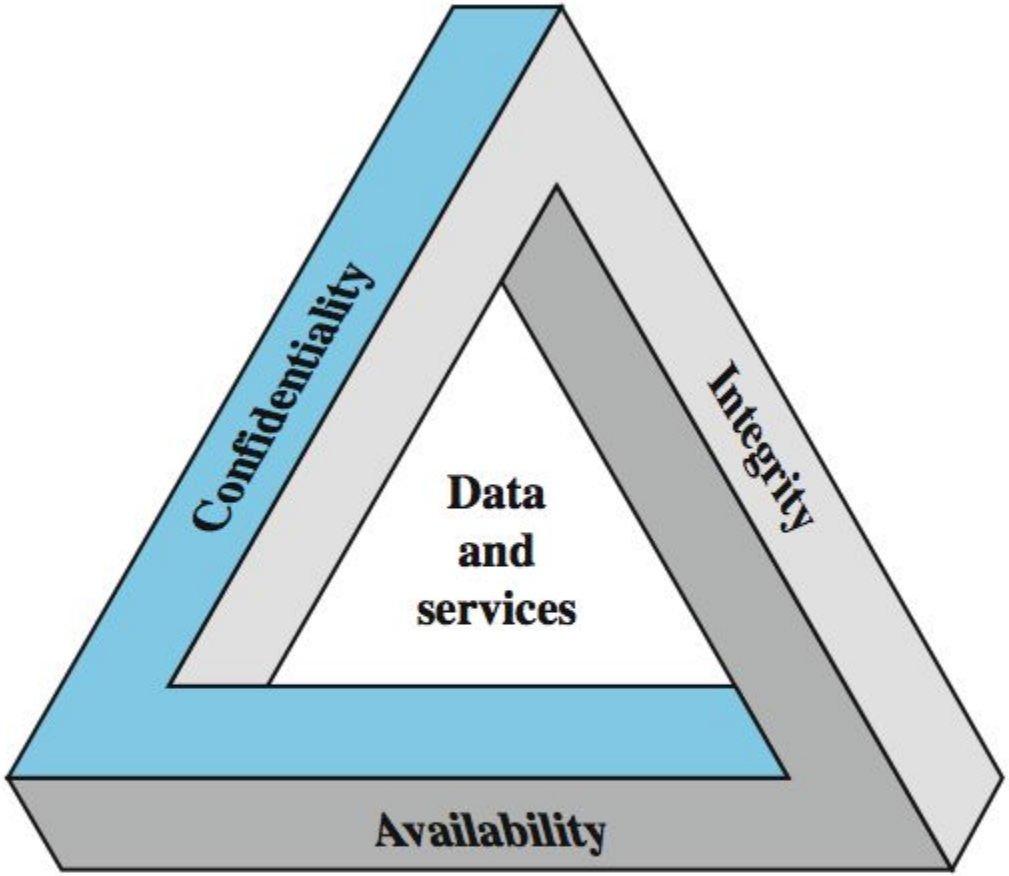
Standards Organizations

- National Institute of Standards & Technology (NIST)
- Internet Society (ISOC)
- International Telecommunication Union Telecommunication Standardization Sector (ITU-T)
- International Organization for Standardization (ISO)
- RSA Labs (de facto)

Computer Security

- the protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications)

Key Security Concepts



Levels of Impact

- can define 3 levels of impact from a security breach
  - Low
  - Moderate
  - High

Low Impact

- The loss could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.
- A limited adverse effect means that, for example, the loss of confidentiality, integrity, or availability might
  - (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced;
  - (ii) result in minor damage to organizational assets;
  - (iii) result in minor financial loss; or
  - (iv) result in minor harm to individuals.

Moderate Impact

- The loss could be expected to have a serious adverse effect on organizational operations, assets, or individuals.
- A serious adverse effect means that, e.g., the loss might
  - (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced;
  - (ii) result in significant damage to organizational assets;
  - (iii) result in significant financial loss; or
  - (iv) result in significant harm to individuals that does not involve loss of life or serious, life-threatening injuries.

High Impact

- The loss could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
- A severe or catastrophic adverse effect means that, for example, the loss might
  - (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions;
  - (ii) result in major damage to organizational assets;
  - (iii) result in major financial loss; or
  - (iv) result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.

Examples of Security Requirements

- confidentiality – student grades
- integrity – patient information
- availability – authentication service
- authenticity – admission ticket
- non-repudiation – stock sell order

Computer Security Challenges

1. not simple – easy to get it wrong
2. must consider potential attacks
3. procedures used counter-intuitive
4. involve algorithms and secret info
5. must decide where to deploy mechanisms
6. battle of wits between attacker / admin
7. not perceived to be of benefit until it fails
8. requires regular monitoring

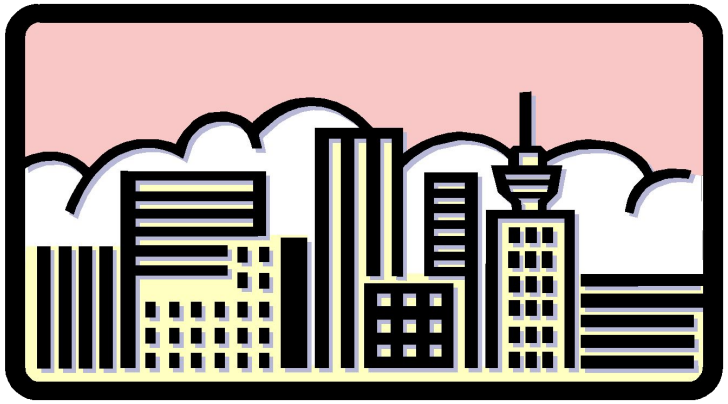
   a process, not an event

1. too often an after-thought
2. regarded as impediment to using system

   “Unusable security is not secure”

OSI Security Architecture

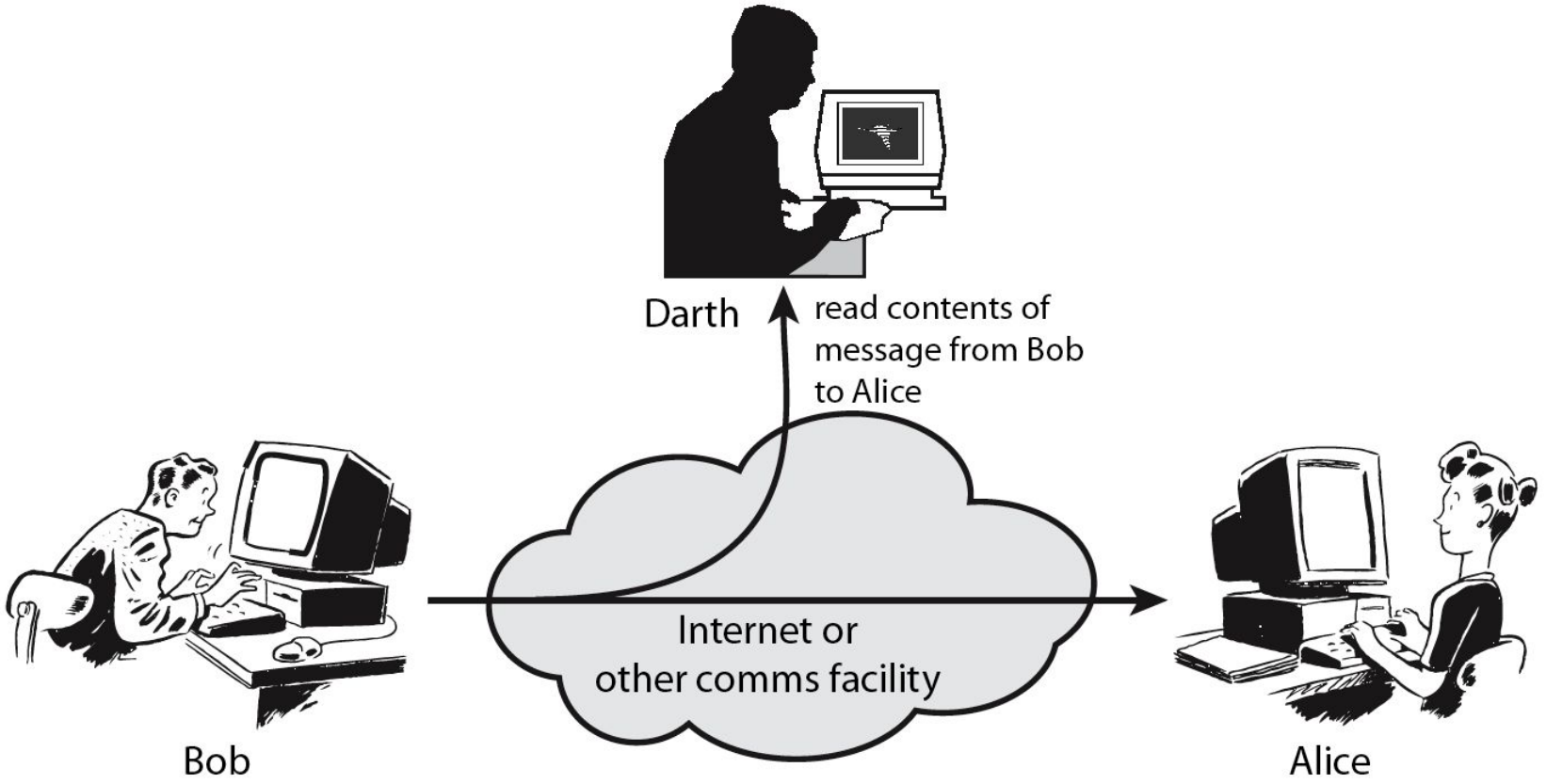
- ITU-T X.800 “Security Architecture for OSI”
- defines a systematic way of defining and providing security requirements
- for us it provides a useful, if abstract, overview of concepts we will study



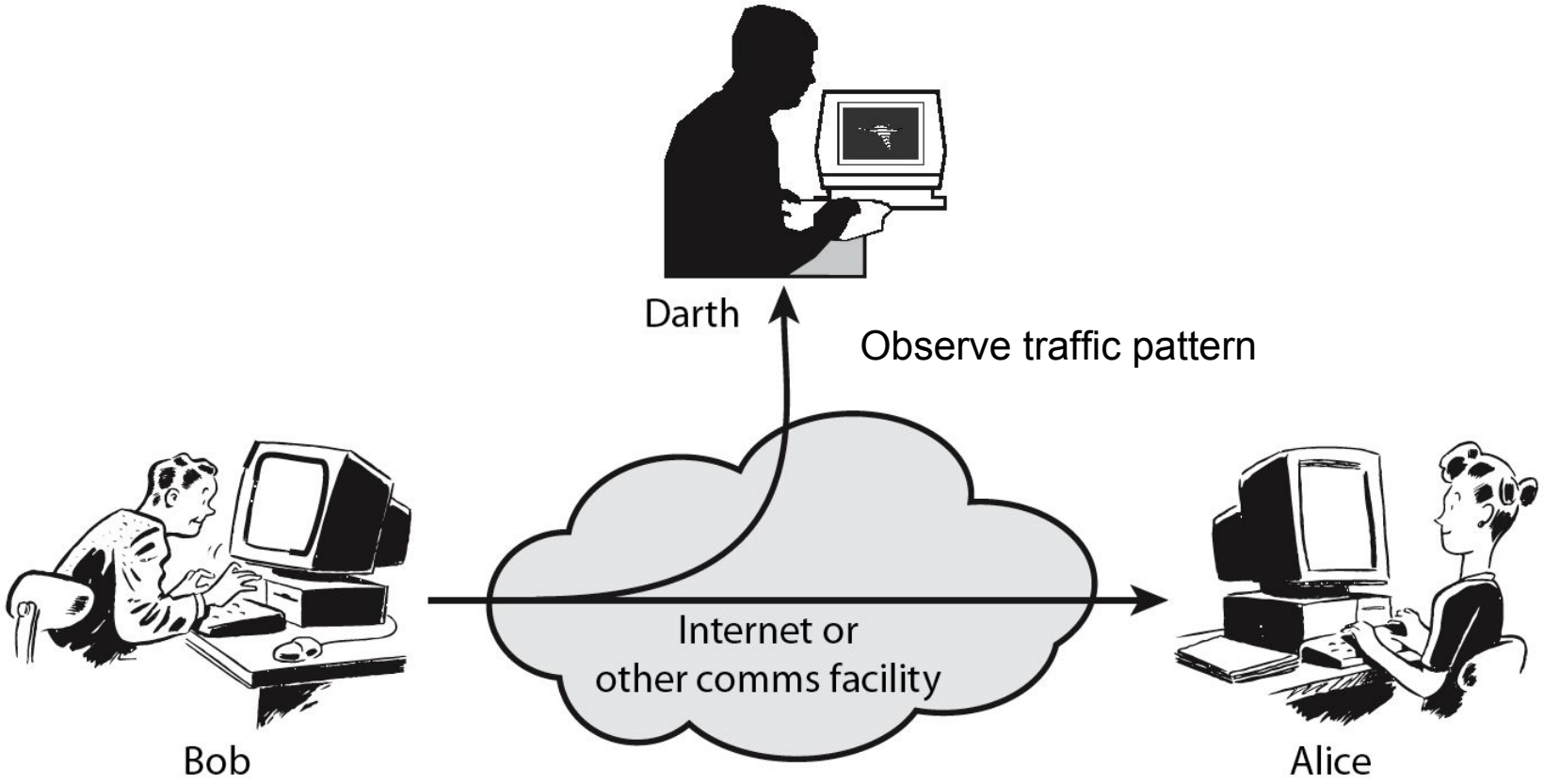
Aspects of Security

- consider 3 aspects of information security:
  - **security attack**
  - **security mechanism (control)**
  - **security service**
- note terms
  - *threat* – a potential for violation of security
  - *vulnerability* – a way by which loss can happen
  - *attack* – an assault on system security, a deliberate attempt to evade security services

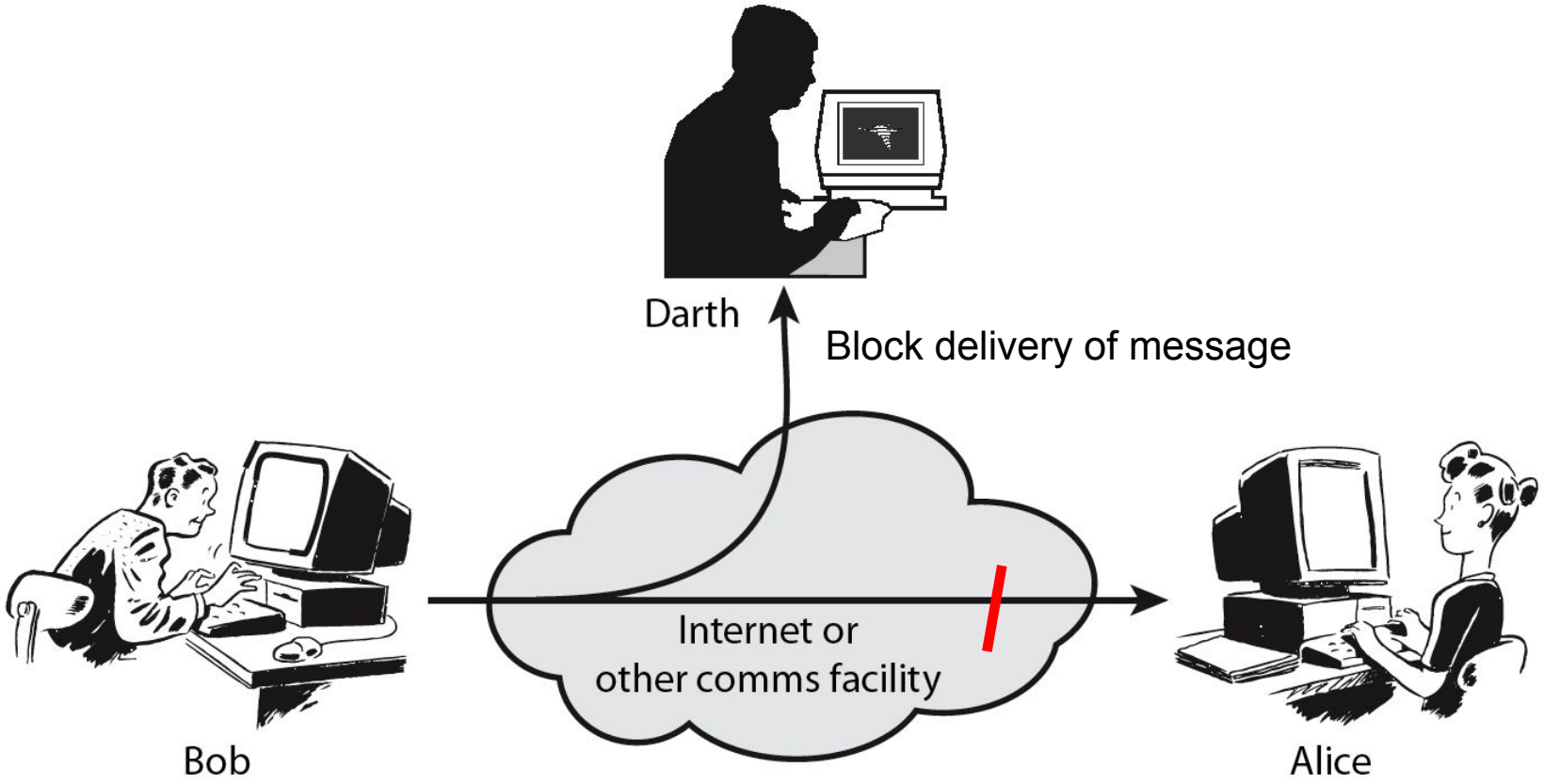
Passive Attack - Interception



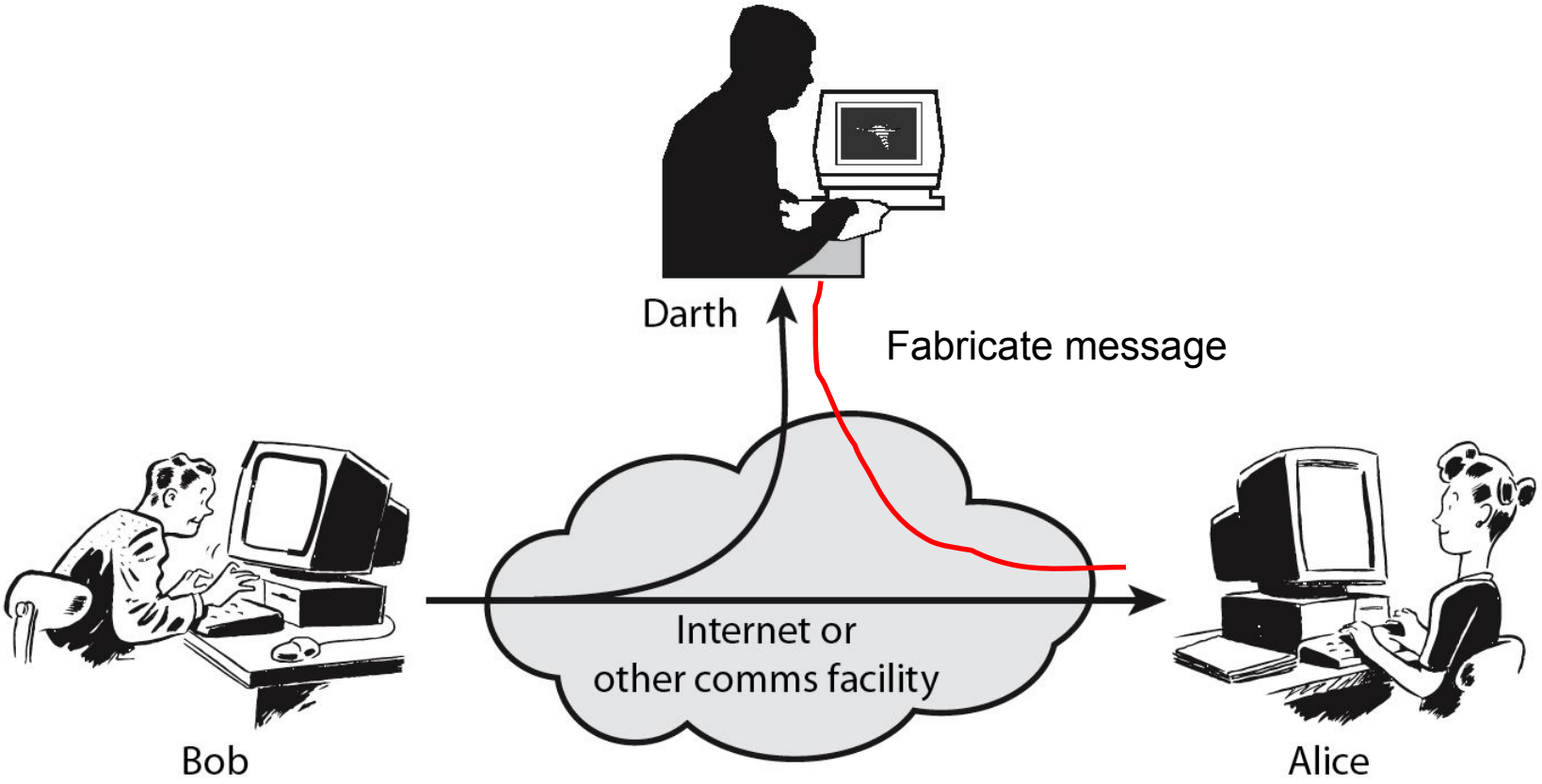
Passive Attack: Traffic Analysis



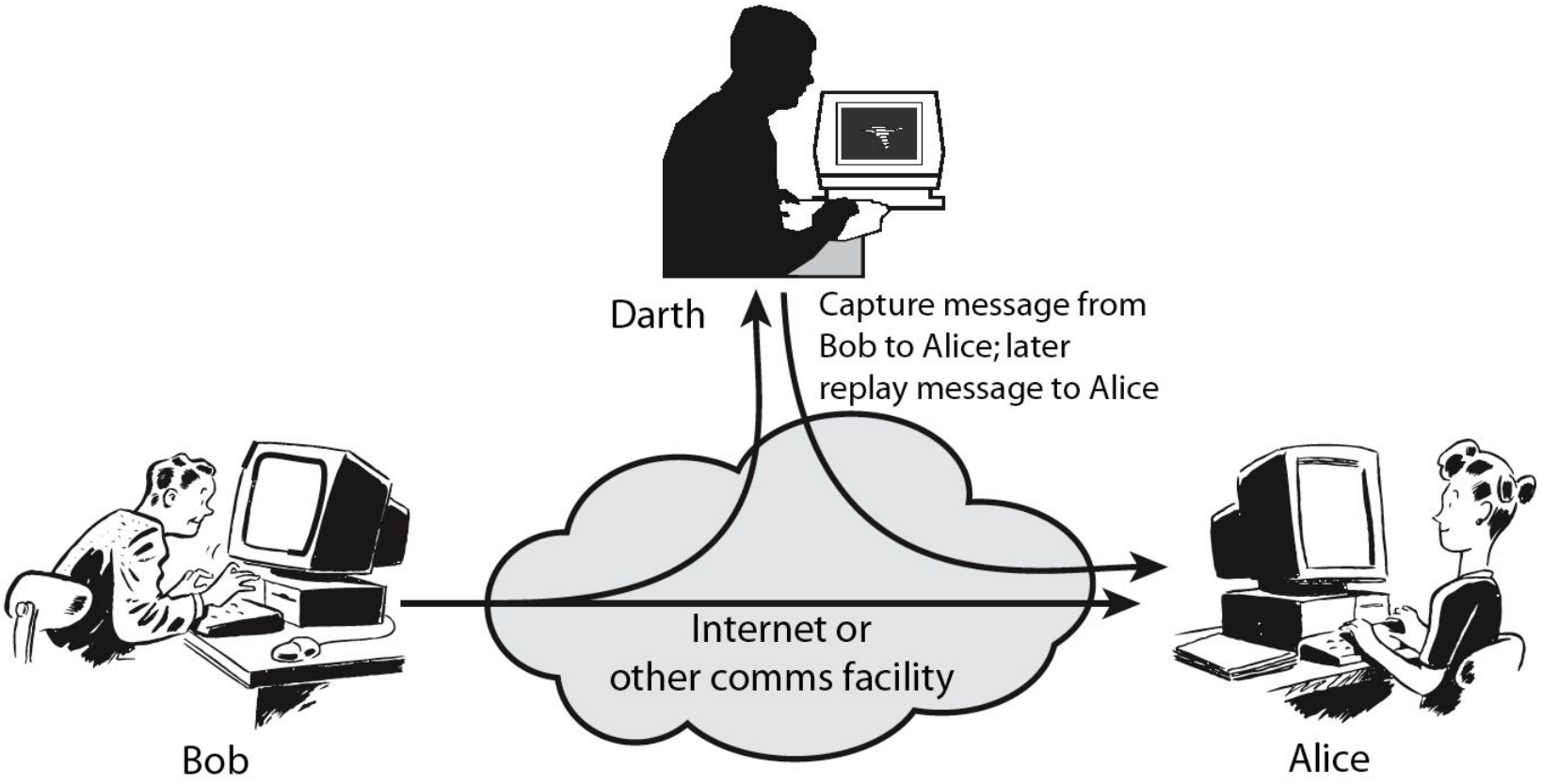
Active Attack: Interruption



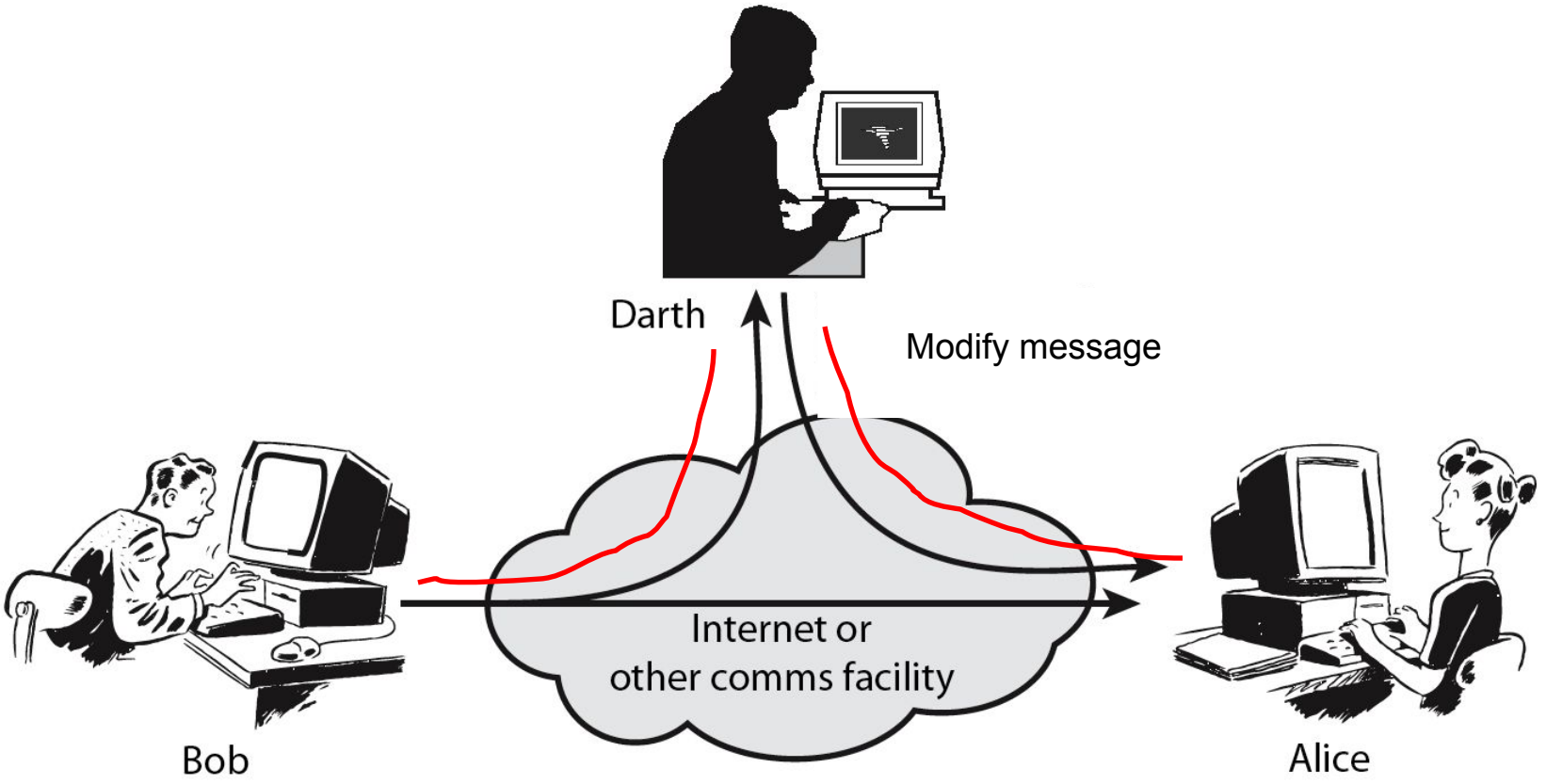
Active Attack: Fabrication



Active Attack: Replay



Active Attack: Modification



Handling Attacks

- Passive attacks – focus on Prevention
  - Easy to stop
  - Hard to detect
- Active attacks – focus on Detection and Recovery
  - Hard to stop
  - Easy to detect

Security Service

- enhance security of data processing systems and information transfers of an organization
- intended to counter security attacks
- using one or more security mechanisms
- often replicates functions normally associated with physical documents
  - which, for example, have signatures, dates; need protection from disclosure, tampering, or destruction; be notarized or witnessed; be recorded or licensed

Security Services

- X.800:

  “a service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers”

- RFC 2828:

  “a processing or communication service provided by a system to give a specific kind of protection to system resources”

Security Services (X.800)

- **Authentication** - assurance that communicating entity is the one claimed
  - have both peer-entity & data origin authentication
- **Access Control** - prevention of the unauthorized use of a resource
- **Data Confidentiality** –protection of data from unauthorized disclosure
- **Data Integrity** - assurance that data received is as sent by an authorized entity
- **Non-Repudiation** - protection against denial by one of the parties in a communication
- **Availability** – resource accessible/usable

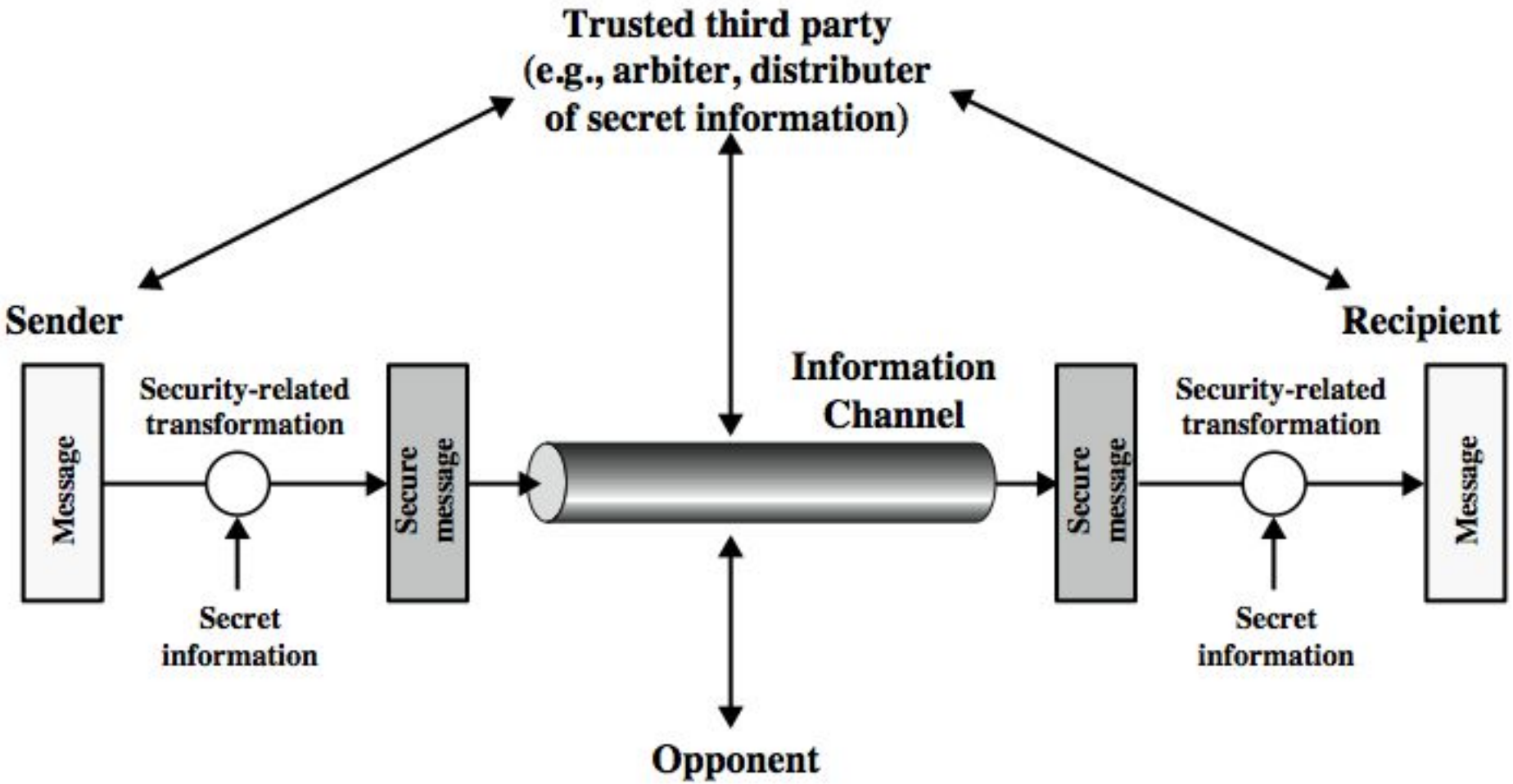
Security Mechanism

- a.k.a. control
- feature designed to detect, prevent, or recover from a security attack
- no single mechanism that will support all services required
- however one particular element underlies many of the security mechanisms in use:
  - **cryptographic techniques**
- hence our focus on this topic

Security Mechanisms (X.800)

- specific security mechanisms:
  - encipherment, digital signatures, access controls, data integrity, authentication exchange, traffic padding, routing control, notarization
- pervasive security mechanisms:
  - trusted functionality, security labels, event detection, security audit trails, security recovery

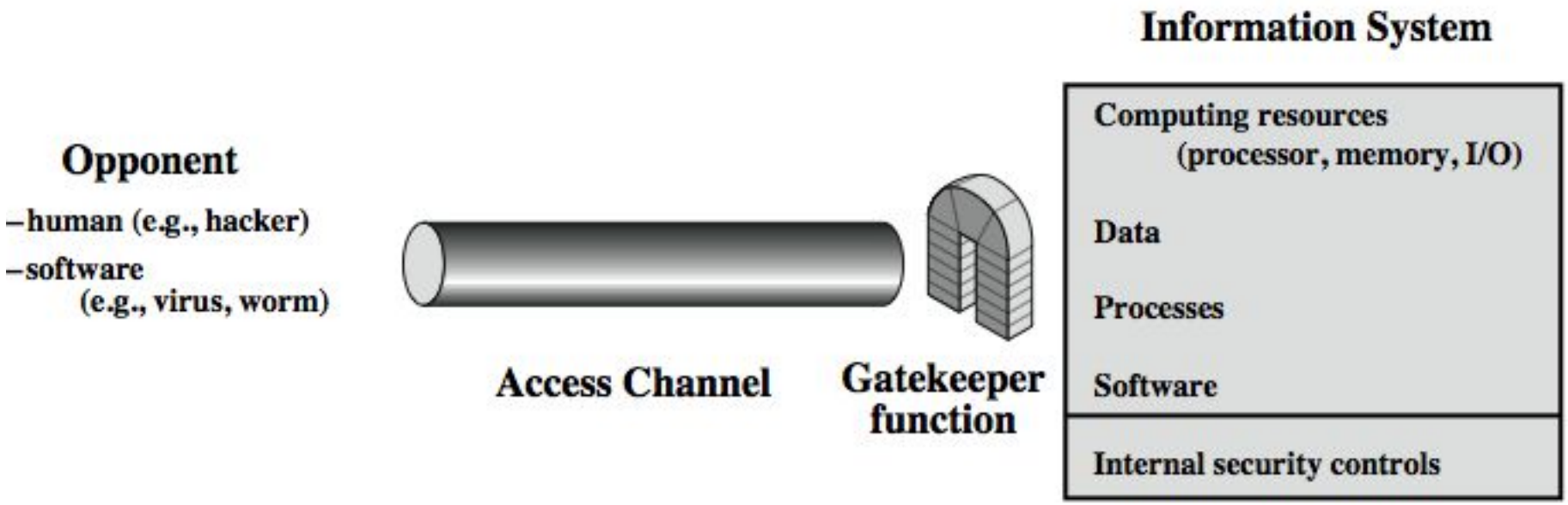
Model for Network Security



Model for Network Security

- using this model requires us to:
  1. design a suitable algorithm for the security transformation
  2. generate the secret information (keys) used by the algorithm
  3. develop methods to distribute and share the secret information
  4. specify a protocol enabling the principals to use the transformation and secret information for a security service

Model for Network Access Security



Model for Network Access Security

- using this model requires us to:
  1. select appropriate gatekeeper functions to identify users
  2. implement security controls to ensure only authorised users access designated information or resources
- note that model does not include:
  1. monitoring of system for successful penetration
  2. monitoring of authorized users for misuse
  3. audit logging for forensic uses, etc.

Summary

- topic roadmap & standards organizations
- security concepts:
  - confidentiality, integrity, availability
- X.800 security architecture
- security attacks, services, mechanisms
- models for network (access) security